

SAAS MULTICLÍNICA

# Matriz de perfis e permissões

Visão ilustrada dos acessos por perfil, operações CRUD, módulos contratados e regras de isolamento efetivamente validadas.

5

perfis existentes

35

operações representativas

175

verificações de autorização

100%

testes aprovados

## Tenant-scoped

Dados limitados à clínica selecionada.

## Plano Parcial

Módulos desmarcados ficam ocultos e retornam 403.

## Escopo médico

Pacientes e faturamentos seguem vínculos e grupos.

## SuperAdministrador

Administra a plataforma, respeitando o plano operacional.

## PERFIS DA APLICAÇÃO

# Quem pode fazer o quê na API?

C = cadastrar · R = visualizar · U = alterar · D = excluir/desativar. “Escopo” significa que o usuário só alcança registros relacionados a ele.

### Administrador

Gestão operacional completa da clínica.

### Médicos

Atendimento dentro do escopo médico.

### Pacientes

Acesso pessoal e restrito.

### Controller

Operação clínica e financeira.

### SuperAdministrador

Gestão global da plataforma.

| Recurso                  | Administrador | Médicos      | Pacientes            | Controller   | SuperAdministrador |
|--------------------------|---------------|--------------|----------------------|--------------|--------------------|
| Dashboard                | R             | R            | R                    | R            | R                  |
| Clínicas                 | —             | —            | —                    | —            | CRUD + troca       |
| Auditoria da plataforma  | —             | —            | —                    | —            | R                  |
| Usuários                 | CRUD          | R/U próprio  | R/U próprio limitado | R próprio    | CRUD               |
| Pacientes                | CRUD          | CRU · escopo | R próprio            | CRU          | CRUD               |
| Arquivos de pacientes    | CRUD          | CRU · escopo | R próprios           | CRU          | CRUD               |
| Observações de pacientes | CRU           | CRU · escopo | —                    | CRU          | CRU                |
| Faturamento médico       | R clínica     | R · escopo   | —                    | R clínica    | R clínica          |
| Grupos médicos           | CRUD          | —            | —                    | CRUD         | CRUD               |
| Agenda e notificações    | CRUD clínica  | CRUD próprio | CRUD próprio         | CRUD próprio | CRUD clínica       |
| CBHPM                    | R + importar  | R            | R                    | R            | R + importar       |
| Licenças médicas         | R/U/liberar   | R própria    | —                    | R própria    | R/U/liberar        |
| Exportações              | Solicitar     | Solicitar    | Solicitar            | Solicitar    | Solicitar          |

● permitido ● permitido com limite/escopo ● negado ● função exclusiva de plataforma

## EXPERIÊNCIA DO USUÁRIO

# Itens exibidos no menu e no dashboard

Um item marcado ainda depende de estar contratado quando a clínica utiliza o plano Parcial.

| Item visual           | Administrador | Médicos | Pacientes | Controller | SuperAdministrador |
|-----------------------|---------------|---------|-----------|------------|--------------------|
| Painel                | ✓             | ✓       | ✓         | ✓          | ✓                  |
| Usuários              | ✓             | —       | —         | —          | ✓                  |
| Meu cadastro          | —             | ✓       | ✓         | —          | —                  |
| Pacientes             | ✓             | ✓       | ✓*        | ✓          | ✓                  |
| Faturamento médico    | ✓             | ✓       | —         | ✓          | ✓                  |
| Grupos médicos        | ✓             | —       | —         | ✓          | ✓                  |
| Agenda e notificações | ✓             | ✓       | ✓         | ✓          | ✓                  |
| Clínicas              | —             | —       | —         | —          | ✓                  |
| Configuração          | ✓             | —       | —         | —          | ✓                  |

### Regra de exclusão

- Clínica: desativação lógica, somente SuperAdministrador.
- Usuários e pacientes: somente Administrador e SuperAdministrador.
- Médico pode alterar paciente do escopo, mas não excluí-lo.
- Evento: proprietário gerencia o próprio; administradores gerenciam a clínica.

### Leitura e alteração de usuário

- Administrador e SuperAdministrador gerenciam todos da clínica.
- Médico consulta e altera o próprio cadastro.
- Controller consulta o próprio cadastro.
- Paciente altera nome, telefone, nascimento e foto; campos de identidade e segurança ficam protegidos.

Menu, acesso direto por URL e autorização da API estão alinhados para Paciente e Controller, sempre respeitando os módulos contratados.

## Como funciona o plano Parcial

A seleção feita no CRUD da clínica controla simultaneamente a interface e a proteção das rotas da API.



## RESULTADO DA REVISÃO

# Alinhamentos e contrato de exportação

As permissões da interface e da API foram alinhadas. Todos podem solicitar exportações, sem ampliar o acesso às informações do perfil.

| Situação                     | Interface atual            | API atual                                         | Resultado/decisão                                          | Estado    |
|------------------------------|----------------------------|---------------------------------------------------|------------------------------------------------------------|-----------|
| Paciente em Pacientes        | Módulo visível em leitura. | Lista somente o próprio prontuário.               | Interface e API alinhadas.                                 | Concluído |
| Paciente em Meu cadastro     | Edição pessoal limitada.   | PUT próprio preserva campos protegidos.           | Nome, telefone, nascimento e foto editáveis.               | Concluído |
| Controller em Agenda         | Menu visível.              | CRUD somente de eventos próprios.                 | Interface e API alinhadas.                                 | Concluído |
| Controller em Grupos médicos | Módulo visível.            | CRUD dentro da clínica selecionada.               | Interface e API alinhadas.                                 | Concluído |
| Exportações                  | Depende do módulo/tela.    | Todos autenticados podem solicitar três recursos. | Conteúdo limitado ao módulo, ClínicaId e escopo do perfil. | Definido  |

**Escopo das exportações:** Pacientes segue clínica, vínculo/grupo médico ou prontuário próprio. Faturamento segue clínica ou escopo médico e não entrega dados ao Paciente. CBHPM limita-se ao que o perfil já pode consultar. A mensagem leva clínica, usuário e perfil; o worker de dados deve aplicar essas regras no servidor.

### Validação automatizada

- 152 aprovados Backend completo
- 108 aprovados Frontend completo
- 175 verificações Matriz de autorização CRUD

### Arquivos de referência

**Backend:** `HemodinksAPI.Tests/ApiAuthorizationMatrixTests.cs`  
**Frontend:** `src/app/appAccess.test.ts`  
**Documento detalhado:** `docs/MATRIZ\_PERFIS\_PERMISSOES.md`

A API é a fonte de verdade para segurança. A interface melhora a experiência escondendo ações, mas nunca deve ser o único mecanismo de autorização.